

Firewall • IDS/IPS • Hashing & Encryption

SOC Analyst L1 | Professor Messer SY0-701 | Shivam Kumar

Topics Covered: Firewall Types (UTM, NGFW, WAF) • IDS/IPS (Detection vs Prevention, Failure Modes, Active/Passive Monitoring) • Protecting Data (Encryption, Hashing, Obfuscation, Tokenization) • Encrypting Data (Stored, Transport, Algorithms, Key Concepts)

■ Section 1 — Firewall Types

The Universal Security Control

- Standard issue — found in homes, offices, and operating systems.
- Controls the flow of network traffic — everything passes through the firewall.
- Corporate control of inbound/outbound data — sensitive materials.
- Blocks inappropriate content — not-safe-for-work, parental controls.
- Protection against evil — anti-virus, anti-malware.

Network-Based Firewalls

- Filter traffic by port number or application.
 - OSI Layer 4 (port numbers) vs. OSI Layer 7 (applications).
 - Traditional firewalls vs. NGFW firewalls.
- Encrypt traffic — VPN between sites.
- Most firewalls can be Layer 3 devices (Routers):
 - Often sits on the ingress/egress of the network.
 - NAT (Network Address Translation) functionality.
 - Authenticate dynamic routing communication.

UTM / All-in-One Security Appliance

- Unified Threat Management (UTM) / Web Security Gateway — bundles many features in one device:
- URL filter / Content inspection
 - Malware inspection
 - Spam filter
 - CSU/DSU, Firewall, IDS/IPS
 - Bandwidth shaper
 - Router, Switch, VPN endpoint

Next-Generation Firewall (NGFW)

- Operates at the OSI Application layer — inspects ALL data in every packet.
- Also called: Application Layer Gateway / Stateful Multilayer Inspection / Deep Packet Inspection.
- Every packet must be analyzed and categorized before a security decision is made.

- Controls traffic flows based on the application (e.g. Microsoft SQL Server, Twitter, YouTube).
- Includes Intrusion Prevention — applies application-specific vulnerability signatures.
- Content filtering — URL filters, controls website traffic by category.

Web Application Firewall (WAF)

- Not like a 'normal' firewall — applies rules to HTTP/HTTPS conversations.
- Allow or deny based on expected input — unexpected input = common attack method.
- Protects against SQL Injection — attacker adds own commands to a SQL query.
- Major focus of PCI DSS (Payment Card Industry Data Security Standard).

■ Section 2 — IDS / IPS (Intrusion Prevention)

What is IPS?

- Intrusion Prevention System (IPS) — watches network traffic in real-time.
- Intrusions include: exploits against OS, applications, buffer overflows, cross-site scripting.

Detection vs. Prevention

- IDS (Intrusion Detection System) — Alarm or Alert only. Cannot block traffic.
- IPS (Intrusion Prevention System) — Stop the attack before it enters the network.

Failure Modes

- We hope for 100% uptime — but this isn't realistic. Eventually something will break.
- Fail-Open — When a system fails, data continues to flow (less secure).
- Fail-Closed — When a system fails, data does NOT flow (more secure).

Device Connections

Active Monitoring:

- System is connected inline: Internet → Firewall → IPS → Core Switch
- Data can be blocked in real-time as it passes by.
- Intrusion Prevention is commonly active.
- Malicious traffic is immediately identified and dropped at the IPS.

Passive Monitoring:

- A copy of the network traffic is examined using a tap or port mirror (SPAN).
- Data CANNOT be blocked in real-time.
- Intrusion Detection is commonly passive.
- No way to block (prevent) traffic — only alert.

■ Section 3 — Hashing & Encryption (Protecting Data)

Geographic Restrictions

- Network location — identify based on IP subnet (difficult with mobile devices).
- Geolocation — determine a user's location:
 - GPS: mobile devices, very accurate.
 - 802.11 wireless: less accurate.
 - IP address: not very accurate.
- Geofencing — automatically allow/restrict access when user is in a specific location.
 - Example: Don't allow this app to run unless you're near the office.

Protecting Data

- A primary job task — an organization is out of business without data.
- Data is everywhere — storage drive, network, CPU, memory.
- Methods: Encryption, security policies.
- Data permissions — not everyone has the same access.

Encryption

- Encode information into unreadable data.
 - Plaintext → Ciphertext (original → encrypted form).
- Two-way street — can convert back if you have the proper key.
- Confusion — encrypted data is drastically different from the plaintext.

Hashing

- Represent data as a short string of text — a message digest / fingerprint.
- One-way trip — impossible to recover the original message from the digest.
 - Used to store passwords confidentially.
- Verify a downloaded document is the same as the original — Integrity.
- Can be a digital signature — Authentication, Non-repudiation, and Integrity.
- Will not have a collision (hopefully) — different messages will not have the same hash.

SHA256 Example: 'My name is Shivam Kumar'

SHA256 Hash: 19da2a3b69f0522c4254ac7a3f8f1cae59333...

SHA256 = 256 bits / 64 hexadecimal characters

Obfuscation

- Make something normally understandable very difficult to understand.
- Take perfectly readable code and turn it into nonsense.
 - Developer keeps the readable code, gives you the 'chicken scratch'.
 - Both sets of code perform exactly the same way.
- Helps prevent the search for security holes — but not impossible.

Data Masking

- A type of obfuscation — hide some of the original data.
- Protects PII (Personally Identifiable Information) and other sensitive data.

- Techniques: substituting, shuffling, encrypting, masking out, etc.

Tokenization

- Replace sensitive data with a non-sensitive placeholder.
 - e.g. SSN 266-12-1112 → 691-61-8539
- Common with credit card processing — use a temporary token during payment.
- This is NOT encryption or hashing — original data and token aren't mathematically related.
- No encryption overhead.

Segmentation

- Many organizations use a single large database — one breach = all data at risk.
- Separate the data — store it in different locations.
- Sensitive data should have stronger security — most sensitive = most secure.

Permission Restrictions

- Control access to an account — more than just username and password.
- Authentication process: password policies, authentication factor policies.
- Permissions after login — another line of defense, prevent unauthorized access.

■ Section 4 — Encrypting Data

Encrypting Stored Data (Data at Rest)

- Protect data on storage devices — SSD, hard drive, USB drive, cloud storage.
- Full-disk and partition/volume encryption — BitLocker, FileVault, etc.
- File encryption — EFS (Encrypting File System), third-party utilities.
- Database encryption:
 - Transparent encryption: encrypt all database info with a symmetric key.
 - Record-level encryption: encrypt individual columns with separate symmetric keys.

Transport Encryption (Data in Transit)

- Protect data traversing the network.
- Encrypting in the application — browsers can communicate using HTTPS.
- VPN (Virtual Private Network):
 - Encrypts all data transmitted over the network, regardless of application.
 - Client-based VPN using SSL/TLS.
 - Site-to-site VPN using IPsec.

Encryption Algorithms

- Many different ways to encrypt data — the proper 'formula' must be used for both encryption and decryption.

- Both sides decide on the algorithm before encrypting data.
- Trade-offs between algorithms: security level, speed, complexity.

DES (Data Encryption Algorithm):

Step 1 → 64-bit plaintext → Step 2 → Initial permutation → Step 3 → Left & Right plaintext → Step 4 → 16 rounds → Step 5 → Final permutation → 64-bit ciphertext

AES (Advanced Encryption Algorithm):

Step 1 → Plaintext (128/192/256 bits) + Security Key → Step 2 → Cipher → Step 3 → Ciphertext (128/192/256 bits)

Cryptographic Keys

- The algorithm is usually a known entity — the only secret is the KEY.
- The key determines the output — encrypted data, hash value, digital signature.
- Keep your key private! It's the only thing protecting your data.

Key Lengths

- Larger keys = more secure — prevents brute-force attacks.
- Symmetric encryption — 128-bit or larger keys are common (getting larger over time).
- Asymmetric encryption — complex prime number calculations, commonly 3,072 bits or larger.

Key Stretching

- A weak key is a weak key — by itself, not very secure.
- Make a weak key stronger by hashing it multiple times:
 - Hash password → hash the hash → hash again → continue...
 - Also called: Key Strengthening.
- Brute force attacks would require reversing each of those hashes.
- Attacker must spend much more time, even if the original key was small.

■ 1.C. COMPLETED — All 4 Videos Done!

Candidate: Shivam Kumar | **Source:** Professor Messer SY0-701 (Free YouTube) | **Date:** June 2026 | **Phase:** 1 — Section 1C